SOLUÇÃO PARA IMPLANTAÇÃO E ACOMPANHAMENTO DA POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

SOLUTION FOR IMPLEMENTATION AND MONITORING OF THE INFORMATION SECURITY POLICY

Samuel Vitor Lopes de Souza

samuelvitorprofissional@gmail.com

Marco Antônio Eugênio Araújo

RESUMO

A Segurança da Informação tornou-se um elemento estratégico para as organizações em razão da crescente dependência de sistemas informatizados e do aumento da incidência de incidentes de segurança. Vazamentos de dados, acessos não autorizados e falhas operacionais evidenciam a necessidade de mecanismos que garantam a proteção adequada dos ativos de informação. Nesse contexto, a Política de Segurança da Informação (PPSI) destaca-se como instrumento fundamental para estabelecer diretrizes, normas e responsabilidades.

Apesar de sua importância, muitas organizações ainda apresentam dificuldades na implantação efetiva e no acompanhamento contínuo da PPSI. Em diversos cenários, a política é tratada apenas como documento normativo para fins de auditoria, sem mecanismos estruturados para mensurar maturidade, monitorar evolução e direcionar melhorias.

Este trabalho apresenta o desenvolvimento de uma solução tecnológica para implantação e acompanhamento da PPSI, integrada ao sistema WorkControl, em arquitetura multi-tenant por *workspace*. A solução estrutura o processo por ciclos de avaliação, aplica diagnóstico por medidas, calcula indicadores globais e por domínio e apoia a geração e execução de planos de ação.

A metodologia adotada envolveu revisão bibliográfica, definição do modelo de dados, implementação de serviços de domínio e validação por prova de conceito com execução ponta a ponta do ciclo PPSI. Os resultados indicam melhoria na rastreabilidade das avaliações, padronização do diagnóstico e apoio objetivo à tomada de decisão. Palavras-chave: Segurança da Informação. Política de Segurança da Informação.

PPSI. Maturidade. Sistemas de Informação.

ABSTRACT

Information Security has become a strategic element for organizations due to the increasing reliance on information systems and the growing number of security incidents.

Instituto Federal de Pernambuco. Campus Recife. Curso Tecnólogo em Análise e Desenvolvimento de Sistemas. 23 de fevereiro de 2026.

Data breaches, unauthorized access, and operational failures highlight the need for mechanisms that ensure adequate protection of information assets. In this context, the Information Security Policy (ISP) is a key instrument for defining guidelines, rules, and responsibilities.

Despite its relevance, many organizations still face difficulties in effectively implementing and continuously monitoring their ISP. In several situations, the policy is handled only as a compliance document, without structured mechanisms to measure maturity, track progress, and drive continuous improvement.

This work presents the development of a technological solution for ISP implementation and monitoring, integrated into the WorkControl system under a multi-tenant workspace architecture. The solution organizes the process through assessment cycles, structured diagnosis by measures, global and domain indicators, and action-plan generation and follow-up.

The adopted methodology included literature review, data-model design, implementation of domain services, and proof-of-concept validation with an end-to-end ISP cycle execution. Results indicate improvements in traceability, diagnostic standardization, and decision-making support. Keywords: Information Security. Information Security Policy. ISP. Maturity. Information Systems.

---

1 INTRODUÇÃO

A transformação digital aumentou a dependência das organizações em sistemas de informação, integrações de dados e serviços conectados. Como consequência, elevou-se também a exposição a riscos de segurança, incluindo indisponibilidade de serviços, perda de integridade de dados e vazamento de informações sensíveis. Nesse cenário, a Política de Segurança da Informação (PPSI) é necessária para formalizar diretrizes, responsabilidades e controles mínimos.

O problema observado é que, na prática, a PPSI frequentemente não possui acompanhamento operacional contínuo. Muitas organizações elaboram a política, mas não conseguem monitorar o grau de implementação de cada controle, medir evolução ao longo do tempo ou transformar lacunas em planos de ação priorizados.

Este trabalho propõe uma solução de software para apoiar a implantação e o acompanhamento da PPSI no contexto do projeto WorkControl. A proposta foi implementada como módulo específico, habilitável por *workspace*, com fluxo estruturado por ciclo de avaliação, diagnóstico, cálculo de indicadores e plano de trabalho.

1.1 Objetivo geral

Desenvolver uma solução tecnológica para implantação e acompanhamento contínuo da Política de Segurança da Informação, com foco em rastreabilidade, mensuração de maturidade e apoio à melhoria contínua.

1.2 Objetivos específicos

- Estruturar o processo de avaliação da PPSI em ciclos com estados controlados;
- Implementar diagnóstico por medidas com respostas padronizadas e justificativas;
- Calcular indicadores globais e por domínio com classificação de maturidade;
- Automatizar a geração de planos de ação a partir de lacunas identificadas;
- Validar o fluxo completo em prova de conceito no sistema implementado.

1.3 Organização do trabalho

A Seção 2 apresenta a fundamentação teórica. A Seção 3 discute trabalhos relacionados. A Seção 4 descreve a solução proposta. A Seção 5 detalha a arquitetura e implementação. A Seção 6 apresenta a prova de conceito. A Seção 7 traz as conclusões e trabalhos futuros.

2 FUNDAMENTAÇÃO TEÓRICA

2.1 Segurança da Informação

A Segurança da Informação é baseada na proteção dos ativos informacionais segundo os princípios de confidencialidade, integridade e disponibilidade. Na prática organizacional, esses princípios exigem combinação entre controles técnicos, processos e governança, com responsabilidades claramente definidas.

Além do aspecto tecnológico, a segurança também depende de disciplina operacional. Sem processos de monitoramento e revisão, controles tendem a perder efetividade ao longo do tempo, especialmente em ambientes dinâmicos e com múltiplos sistemas.

2.2 Política de Segurança da Informação

A PPSI define diretrizes institucionais para uso, proteção e tratamento das informações. Seu objetivo não é apenas documental, mas operacional: orientar comportamentos, estabelecer critérios de conformidade e apoiar decisões de gestão de risco.

Para que a política gere valor, é necessário acompanhamento periódico dos controles, registro de evidências e correção estruturada de não conformidades. Assim, a implantação da PPSI deve ser tratada como processo contínuo e não como evento pontual.

No contexto de organizações de pequeno e médio porte, a literatura também aponta baixa maturidade em práticas de segurança, limitações orçamentárias e barreiras de capacitação como fatores recorrentes para dificuldades de implementação (Júnior; Becker; Johnson, 2023; Chidukwani; Zander; Koutsakis, 2024; Johnson *et al.*, 2024).

2.3 Origem do PPSI no contexto adotado

No contexto deste trabalho, a sigla PPSI também se relaciona ao Programa de Privacidade e Segurança da Informação do Governo Federal, referência utilizada na estruturação do framework aplicado no sistema. Em fonte oficial, o programa foi instituído pela Portaria SGD/MGI nº 852, de 28 de março de 2023, no âmbito do Ministério da Gestão e da Inovação em Serviços Públicos, com condução da Secretaria de Governo Digital (SGD) (Ministério da Gestão e da Inovação em Serviços Públicos, 2023c,b).

Assim, a origem institucional do PPSI adotado como referência não está associada a um autor individual, mas a uma iniciativa pública de governança digital liderada pela SGD/MGI para os órgãos do SISP. A motivação declarada é elevar maturidade e resiliência em privacidade e segurança da informação, apoiar adequação normativa (como LGPD e normativos de segurança) e reduzir riscos operacionais em serviços digitais governamentais (Ministério da Gestão e da Inovação em Serviços Públicos, 2023a,b).

2.4 Modelos de maturidade em segurança

Modelos de maturidade permitem avaliar o estágio de implementação dos controles e a capacidade da organização de sustentar práticas de segurança ao longo do tempo. O uso de níveis facilita comparação entre ciclos, priorização de investimentos e comunicação executiva de resultados.

Na literatura e na prática institucional, modelos como CMMI, SSE-CMM e C2M2 compartilham uma lógica comum: definição de capacidades por estágios progressivos, critérios observáveis para evolução e foco em institucionalização de processos. Embora tenham escopos diferentes (engenharia de software, engenharia de segurança e maturidade em ciberenergia), esses modelos reforçam que maturidade não é apenas existência de controle, mas também repetibilidade, gestão e melhoria contínua.

No presente trabalho, a maturidade é calculada por pontuação normalizada (0 a 1) e classificada em cinco níveis crescentes, permitindo análise global e por domínio temático. A escala foi definida como instrumento operacional do módulo PPSI para leitura gerencial rápida e comparação entre ciclos, sem pretensão de substituir modelos normativos completos.

2.5 Escala de maturidade adotada

As faixas utilizadas no sistema (`INITIAL`, `BASIC`, `INTERMEDIATE`, `IMPROVING`, `ADVANCED`) foram definidas como convenção de classificação para o contexto desta implementação. O objetivo prático foi separar cenários críticos (abaixo de 0,30), básicos (0,30 a 0,49), intermediários (0,50 a 0,69), em evolução (0,70 a 0,89) e avançados (a partir de 0,90), preservando interpretação simples pelos gestores.

Trata-se, portanto, de uma escala heurística de apoio à decisão, adequada à prova de conceito e ao acompanhamento evolutivo interno. Como limitação, reconhece-se que a calibração dos limiares ainda requer validação empírica com maior volume de ciclos e comparação com benchmarks externos.

2.6 Indicadores e melhoria contínua

Indicadores operam como mecanismo de gestão: transformam respostas de diagnóstico em informação objetiva para decisão. Quando acoplados a ciclos periódicos e planos de ação, viabilizam melhoria contínua orientada por dados, reduzindo subjetividade na condução da PPSI.

2.7 Digitalização de instrumentos de governança

Instrumentos de governança organizacional tradicionalmente baseados em planilhas eletrônicas apresentam limitações operacionais relevantes, especialmente quando utilizados para processos contínuos de acompanhamento e melhoria. Entre essas limitações destacam-se a ausência de controle estruturado de versões, dificuldade de rastreabilidade histórica, risco de inconsistência no preenchimento manual e limitação na consolidação automatizada de indicadores.

A digitalização desses instrumentos por meio de plataformas estruturadas permite padronização do fluxo de avaliação, aplicação de regras de validação, persistência histórica dos dados e cálculo automatizado de métricas de desempenho. Além disso, sistemas digitais viabilizam controle de ciclo de vida, segregação de contexto por organização e integração com mecanismos de auditoria.

No contexto da Política de Segurança da Informação, a transformação da ferramenta PPSI de planilha para sistema estruturado representa avanço significativo na maturidade do processo de governança, permitindo que o diagnóstico deixe de ser um artefato estático e passe a ser um mecanismo dinâmico de acompanhamento contínuo.

Esse movimento se torna especialmente relevante em cenários de baixa conformidade regulatória no tratamento de dados, como observado em estudos sobre organizações brasileiras em contexto de LGPD (Fernandes *et al.*, 2022).

3 TRABALHOS RELACIONADOS

Soluções e frameworks consolidados, como ISO/IEC 27001, NIST Cybersecurity Framework e CIS Controls, oferecem referência robusta para governança de segurança. Entretanto, a literatura aponta que sua adoção em organizações de menor porte pode demandar esforço elevado de adaptação, principalmente em ambientes com equipes reduzidas e baixa maturidade inicial (Júnior; Becker; Johnson, 2023; Angelopoulos *et al.*, 2022; Cheenepalli *et al.*, 2025).

No recorte de SMEs, (Curtin *et al.*, 2024) propõem ferramenta de avaliação de risco com foco em simplicidade de uso; o principal ganho é acessibilidade, mas sem integração nativa com ciclo formal de melhoria. Em (Getir, 2024), a ênfase está em modelagem de ameaças para microempresas, contribuindo para identificação de riscos técnicos, porém com menor cobertura do acompanhamento gerencial pós-diagnóstico. Trabalhos como (Rana *et al.*, 2024; S. *et al.*, 2024; Papathanasiou *et al.*, 2025) reforçam abordagens de baixo custo, mas tendem a priorizar orientação prescritiva em detrimento de automação operacional ponta a ponta.

Em contraste, a proposta deste trabalho integra, no mesmo módulo, diagnóstico estruturado por medidas, regra explícita de ciclo de vida, cálculo automático de indicadores e geração de plano de ação vinculada às lacunas identificadas. Além disso, o isolamento por *workspace* permite uso multi-tenant no contexto do WorkControl, aspecto pouco explorado nos trabalhos revisados.

4 VISÃO GERAL DA SOLUÇÃO

A solução foi implementada como módulo de domínio no WorkControl, com ativação por *feature flag* (`workspaces.is_ppsi_enabled`). Quando habilitado, o sistema disponibiliza rotas web e API para todas as etapas da jornada PPSI.

O fluxo funcional ocorre em sete etapas principais:

1. Habilitação do módulo no *workspace*;
2. Criação do ciclo de avaliação;
3. Início formal do ciclo;
4. Resposta das medidas no diagnóstico;
5. Encerramento do ciclo com validação de pendências;
6. Cálculo e visualização de indicadores;
7. Geração e acompanhamento dos planos de ação.

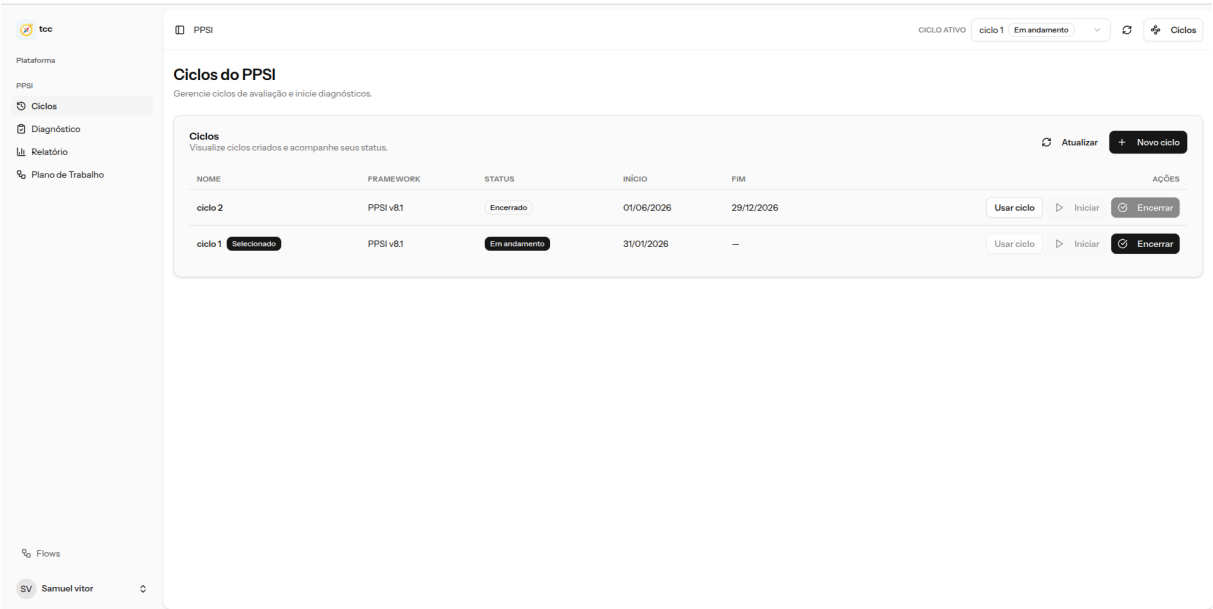

Figura 1 – Visão geral do módulo PPSI no WorkControl

O diagnóstico utiliza catálogo estruturado de domínios, controles, medidas e opções de resposta (com peso e sinalização de aplicabilidade no score). Esse desenho permite padronização da coleta e comparabilidade entre ciclos.

Diferentemente da abordagem baseada exclusivamente em planilha eletrônica, a solução implementada introduz controle formal de ciclo de vida, validações automáticas de consistência, cálculo imediato de indicadores normalizados e geração estruturada de planos de ação.

Enquanto a planilha depende de consolidação manual e interpretação subjetiva dos resultados, a plataforma digital garante padronização do diagnóstico, redução de erros operacionais e maior confiabilidade na análise evolutiva entre ciclos de avaliação. Dessa forma, o sistema transforma a PPSI de instrumento documental em processo operacional mensurável.

5 ARQUITETURA E IMPLEMENTAÇÃO

A arquitetura segue separação em camadas de apresentação, aplicação e persistência, com serviços de domínio para regras de negócio críticas (ciclo de vida, cálculo de indicadores e geração de planos).

5.1 Backend

No backend Laravel, as rotas da API estão sob o prefixo `/api/ppsi`, protegidas por autenticação e middleware de habilitação do módulo. O middleware valida o contexto do *workspace* e bloqueia acesso quando a PPSI está desabilitada.

As principais entidades persistidas incluem: organizações, ciclos, respostas, indicadores e planos de ação. As tabelas `ppsi_*` suportam o fluxo completo de avaliação e auditoria do processo.

5.2 Frontend

No frontend React/Inertia, as páginas principais estão organizadas em ciclos, diagnóstico, relatório e plano de trabalho. O layout compartilhado do módulo mantém o seletor de ciclo ativo e centraliza o contexto da avaliação.

A navegação foi desenhada para operação sequencial, reduzindo ambiguidades de uso: primeiro diagnosticar, depois consolidar indicadores e por fim tratar as lacunas com ações planejadas.

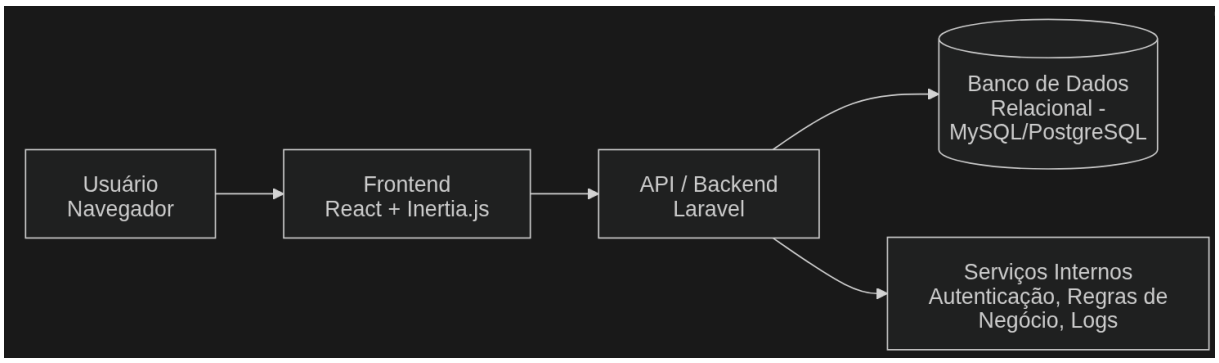

Figura 2 – Arquitetura da solução implementada

5.3 Regras de ciclo de vida

O ciclo possui três estados: `draft`, `in_progress` e `closed`. A transição é validada por regras de negócio: só é possível iniciar um ciclo em rascunho e só é possível encerrá-lo quando não existem medidas pendentes.

Em caso de pendências, a API retorna conflito com a contagem de itens não respondidos, impedindo fechamento inconsistente e mantendo a confiabilidade dos indicadores.

5.4 Cálculo de indicadores

Os indicadores são calculados a partir das respostas válidas para pontuação. Para cada resposta aplicável, o sistema soma o peso no numerador e incrementa o denominador, resultando em score normalizado entre 0 e 1.

A classificação de maturidade segue faixas:

- menor que 0,30: `INITIAL`;
- menor que 0,50: `BASIC`;
- menor que 0,70: `INTERMEDIATE`;
- menor que 0,90: `IMPROVING`;
- maior ou igual a 0,90: `ADVANCED`.

O sistema persiste resultados por domínio e resultado global por ciclo, permitindo análise histórica da evolução da maturidade.

5.5 Geração de plano de ação

Após diagnóstico, o gerador de plano cria ações automaticamente para lacunas identificadas, com prioridade proporcional à distância para implementação plena do controle. Medidas não respondidas recebem prioridade máxima.

Essa automação reduz esforço manual inicial e acelera a conversão de diagnóstico em execução prática de melhoria.

6 PROVA DE CONCEITO

A prova de conceito consistiu na execução ponta a ponta do módulo PPSI em ambiente funcional do WorkControl. O objetivo foi verificar consistência das regras e viabilidade de uso no processo real de acompanhamento.

6.1 Cenário de validação

Foi considerado um *workspace* com o módulo habilitado e dados-base do framework PPSI carregados por seeder. Em seguida, um ciclo foi criado e iniciado para preenchimento do diagnóstico.

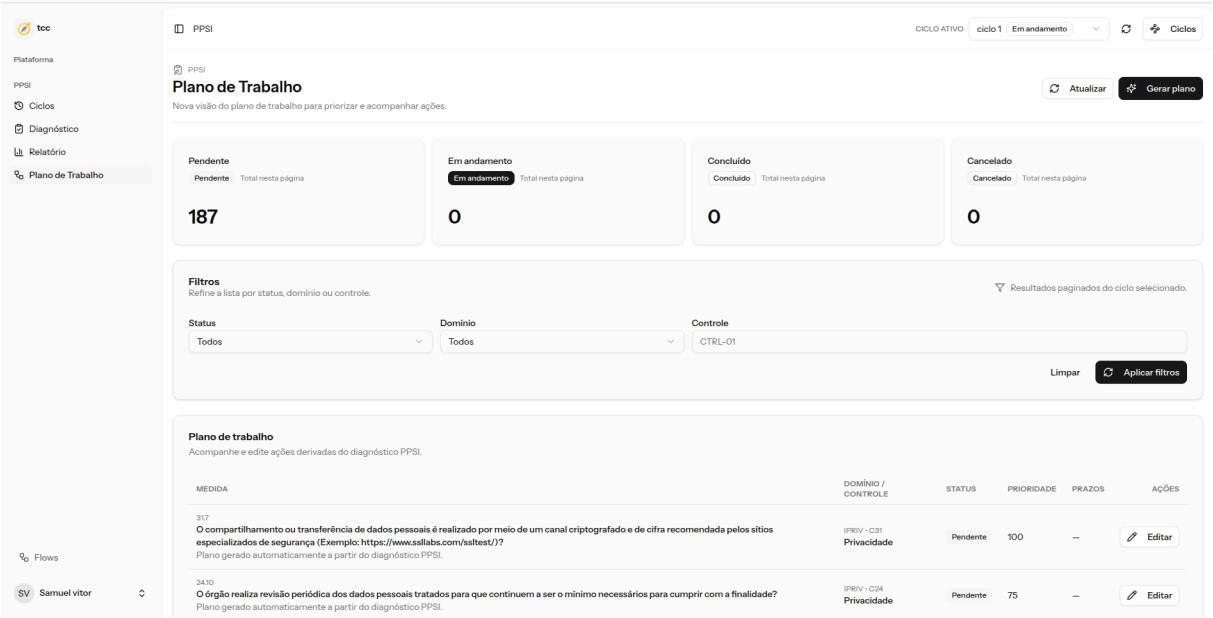

Figura 3 – Plano de ação gerado automaticamente a partir do diagnóstico

6.2 Etapas executadas

1. Criação de ciclo em estado `draft`;
2. Início do ciclo e definição de data de início;
3. Resposta das medidas por domínio;
4. Tentativa de encerramento com e sem pendências;
5. Cálculo de indicadores após encerramento válido;
6. Geração automática de plano de trabalho;
7. Atualização manual de status e responsáveis das ações.

Conforme a Figura 5, após o encerramento válido do ciclo, o sistema consolidou os indicadores globais e por domínio para suporte à priorização das ações.

6.3 Análise dos resultados

Na execução da prova de conceito, o score global observado foi 0,50, classificado como `INTERMEDIATE` pela escala adotada. Esse resultado indica que parte relevante das medidas já apresenta implementação consistente, mas ainda existem lacunas suficientes para impedir enquadramento em níveis superiores.

Do ponto de vista de coerência interna, o resultado foi compatível com o diagnóstico registrado: domínios com maior volume de respostas parciais ou não implementadas reduziram a média global, e essas mesmas lacunas foram refletidas como itens priorizados no plano de ação (Figura 3). Isso confirma aderência entre entrada (respostas), processamento (cálculo) e saída (priorização).

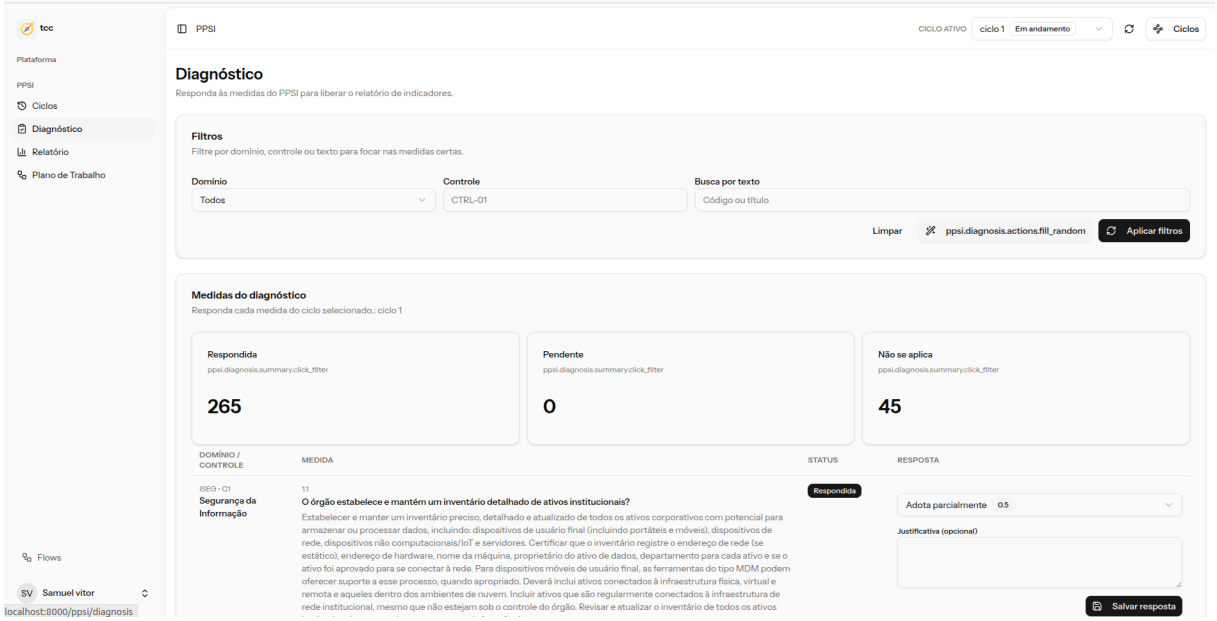

Figura 4 – Execução do diagnóstico no ciclo de avaliação

Como limitação da análise, esta avaliação foi realizada em um único cenário de validação, sem comparação estatística entre organizações ou ciclos longos. Assim, a evidência apresentada deve ser interpretada como validação funcional e não como comprovação definitiva de desempenho comparativo da abordagem.

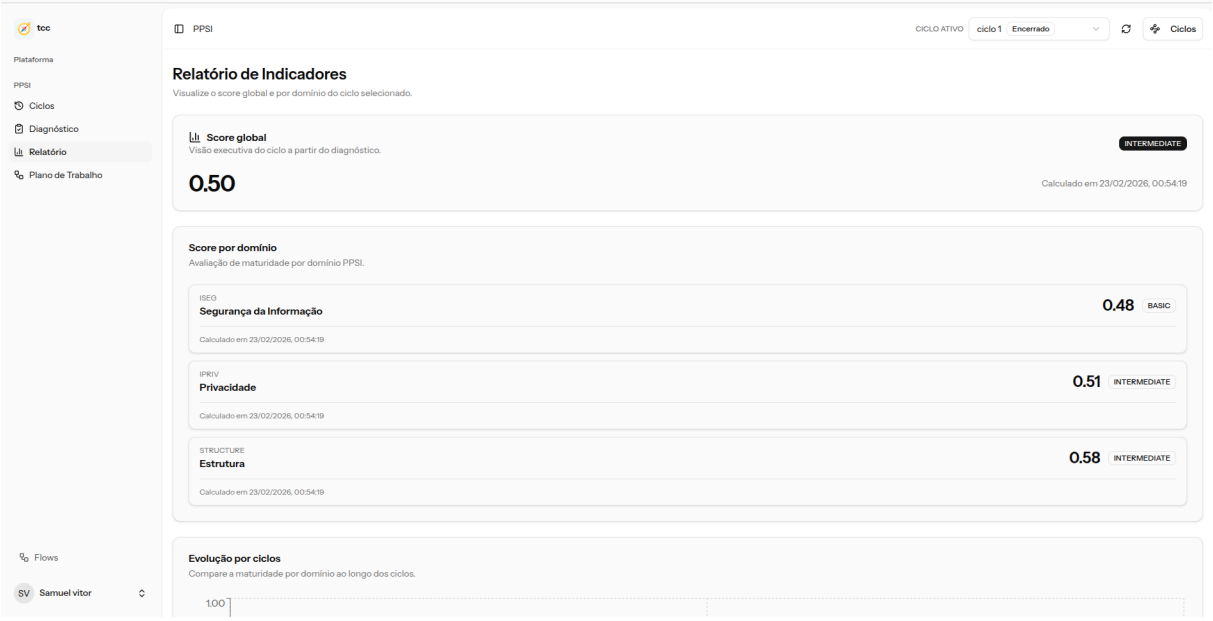

Figura 5 – Visualização de indicadores e maturidade

7 CONCLUSÃO

Este trabalho apresentou uma solução para implantação e acompanhamento da Política de Segurança da Informação, implementada no projeto WorkControl. A proposta materializa um fluxo contínuo de governança, estruturado em ciclo, diagnóstico, indicador e ação.

Como contribuição prática, a solução transforma a PPSI de artefato documental em processo mensurável e gerenciável. O uso de regras de ciclo de vida, pontuação normalizada e geração automática de planos reduz subjetividade e aumenta previsibilidade operacional.

Do ponto de vista acadêmico, o trabalho demonstra a aplicação prática de conceitos de governança de segurança da informação, modelagem de domínio e arquitetura em camadas, integrando fundamentação teórica com implementação real em ambiente multi-tenant. A solução desenvolvida evidencia como instrumentos conceituais podem ser operacionalizados por meio de engenharia de software estruturada.

Entre as limitações, destacam-se a necessidade de expansão da cobertura de testes para cenários de tenancy em todos os endpoints, a ausência de comparação experimental com abordagens alternativas e a importância de validação longitudinal em múltiplos contextos organizacionais. Também se reconhece que a metodologia adotada priorizou implementação e validação funcional por prova de conceito, sem definição prévia de métricas estatísticas de efetividade.

Como trabalhos futuros, recomendam-se:

- ampliação da suíte de testes automatizados para regras de negócio críticas;
- refinamento do OpenAPI para cobertura integral dos endpoints do módulo;
- integração com fontes externas para evidências de controles;

- aplicação da solução em estudos de caso reais com comparação entre ciclos.

REFERÊNCIAS

ANGELOPOULOS, Marios *et al.* Cybersecurity Risk Assessment Frameworks Tailored for SMEs and Lightweight Controls. **Electronics**, v. 13, n. 19, 2022. Acesso em: 24 jul. 2025. Disponível em: https://www.mdpi.com/2079-9292/13/19/3910.

CHEENEPALLI, Jayaprakashreddy *et al.* **Advancing DevSecOps in SMEs: Challenges and Best Practices for Secure CI/CD Pipelines**. [*S. l.: s. n.*], 2025. https://arxiv.org/abs/2503.22612. Acesso em: 24 jul. 2025.

CHIDUKWANI, Alladean; ZANDER, Sebastian; KOUTSAKIS, Polychronis. Cybersecurity preparedness of small-to-medium businesses: A Western Australia study with broader implications. **Computers & Security**, v. 145, p. 104026, 2024. DOI: 10.1016/j.cose.2024.104026.

CURTIN, Miriam *et al.* **Development of a cyber risk assessment tool for Irish small business owners**. [*S. l.: s. n.*], 2024. https://arxiv.org/abs/2408.16124. Acesso em: 24 jul. 2025.

FERNANDES, Tatiane Oliveira *et al.* Diagnostic of Data Processing by Brazilian Organizations—A Low-Compliance View. **Information**, v. 12, n. 4, 2022. Acesso em: 24 jul. 2025. Disponível em: https://www.mdpi.com/2078-2489/12/4/168.

GETIR, Etkin. **Development of a threat modelling framework and a web-based threat modelling tool for micro businesses**. [*S. l.: s. n.*], 2024. https://arxiv.org/abs/2411.14450. Acesso em: 24 jul. 2025.

JOHNSON, Michael *et al.* Cybersecurity Preparedness of Small-to-Medium Businesses. **Computers & Security**, 2024. Acesso em: 24 jul. 2025. Disponível em: https://www.sciencedirect.com/science/article/pii/S0167404824003316.

JÚNIOR, Carlos Rombaldo; BECKER, Ingolf; JOHNSON, Shane. **Unaware, Unfunded and Uneducated: A Systematic Review of SME Cybersecurity**. [*S. l.: s. n.*], 2023. https://arxiv.org/abs/2309.17186. Acesso em: 24 jul. 2025.

MINISTÉRIO DA GESTÃO E DA INOVAÇÃO EM SERVIÇOS PÚBLICOS. **Cartilha com instruções para aplicação da ferramenta de autoavaliação do Programa de Privacidade e Segurança da Informação (PPSI)**. [Online]. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/arquivos/SEI_MGI37571457Portaria.pdf. Acesso em: 23 fev. 2026.

MINISTÉRIO DA GESTÃO E DA INOVAÇÃO EM SERVIÇOS PÚBLICOS. **Framework de Privacidade e Segurança da Informação (PPSI)**. [Online]. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-segurança/framework-ppsi. Acesso em: 23 fev. 2026.

MINISTÉRIO DA GESTÃO E DA INOVAÇÃO EM SERVIÇOS PÚBLICOS. **Programa de Privacidade e Segurança da Informação (PPSI)**. [Online]. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/privacidade-e-seguranca/programa-de-privacidade-e-seguranca-da-informacao-ppsi. Acesso em: 23 fev. 2026.

PAPATHANASIOU, Anastasios *et al.* Cybersecurity Guide for SMEs: Protecting Small and Medium-Sized Enterprises in the Digital Era. **Journal of Information Security**, v. 16, p. 1–43, 2025. DOI: 10.4236/jis.2025.161001.

RANA, R. A. *et al.* **Cost-Effective Cybersecurity Framework for Small and Medium-Sized Enterprises**. [*S. l.: s. n.*], 2024. https://www.researchgate.net/publication/384138498. Acesso em: 24 jul. 2025.

S., Yasmin *et al.* **Cybersecurity Guide for SMEs: Protecting Small and Medium-sized Enterprises**. [*S. l.: s. n.*], 2024. https://www.scirp.org/journal/paperinformation?paperid=137455. Acesso em: 24 jul. 2025.